

IoT-Sicherheit

Wenn Dinge zur Bedrohung
werden

Agenda

- **Industrieanlagen im Visier** – Stuxnet und die Besonderheiten von OT
- **Das Smart Home** – Mirai-Botnet und Consumer-IoT-Risiken
- **OWASP IoT Top 10** – die wichtigsten Schwachstellenkategorien

Industrieanlagen im Visier

Wenn ein Cyberangriff Maschinen zerstört

Fallstudie: Stuxnet (2010)

- Was geschah?
 - Hochkomplexe Schadsoftware infizierte die Steuerungssysteme der iranischen Urananreicherungsanlage Natanz
 - Manipulierte gezielt die Drehzahl der Zentrifugen – mal zu schnell, mal zu langsam – und zeigte den Betreibern gleichzeitig **normale Messwerte** an
 - Ergebnis: rund 1.000 Zentrifugen physisch zerstört, ohne dass die Ursache zunächst erkennbar war

Wie kam die Schadsoftware in die Anlage?

- Die Anlage war **air-gapped** – keine direkte Verbindung zum Internet
- Verbreitung über infizierte **USB-Sticks**, vermutlich über Zulieferer oder Mitarbeitende eingeschleust
- Nutzte **vier Zero-Day-Schwachstellen** in Windows gleichzeitig – ein Aufwand, der auf staatliche Ressourcen hindeutet
- zielte gezielt auf **SPS (speicherprogrammierbare Steuerungen)** von Siemens einer bestimmten Konfiguration

Merksatz: Ein Air Gap schützt nicht vor USB-Sticks und Menschen.

Zero-Day: Sicherheitslücke, für die noch kein Patch verfügbar ist. **SPS** ist die deutsche Bezeichnung für **PLC** (Programmable Logic Controller).

Was ist an Industrieanlagen besonders?

- **Operational Technology (OT):** Hard- und Software, die physische Prozesse steuert und überwacht (Maschinen, Ventile, Motoren)
 - Abgrenzung zur klassischen **Information Technology (IT)**, die primär Daten verarbeitet
- Typische OT-Begriffe:
 - **ICS (Industrial Control Systems):** Sammelbegriff für Steuerungssysteme in der Industrie
 - **SCADA (Supervisory Control and Data Acquisition):** Systeme zur Fernüberwachung und -steuerung
 - **SPS / PLC (Programmable Logic Controller):** steuert einzelne Maschinen oder Anlagenteile direkt

IT und OT ticken unterschiedlich

IT-Systeme

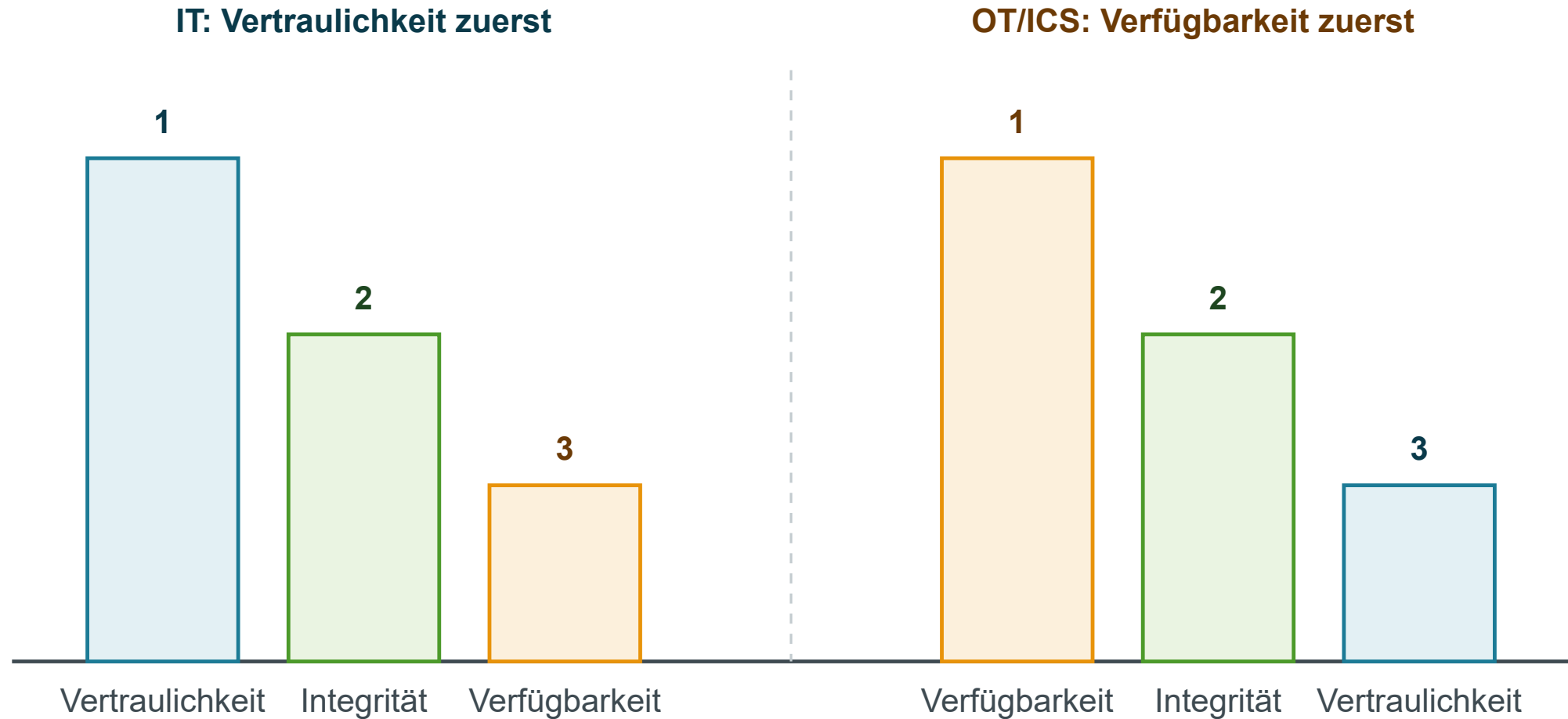
- Priorität: **Vertraulichkeit** zuerst
- Kurze Update-Zyklen (Tage/Wochen)
- Lebensdauer: 3–5 Jahre
- Ausfall = ärgerlich, aber selten gefährlich

OT / ICS

- Priorität: **Verfügbarkeit** zuerst
- Patches oft erst bei geplantem Stillstand
- Lebensdauer: 15–20+ Jahre
- Ausfall = Produktionsstopp oder **physischer Schaden**

Abwägung: Ein sofortiger Neustart für einen Patch kann eine laufende Produktionsanlage stoppen; ein Aufschub lässt die Schwachstelle länger offen.

Die CIA-Reihenfolge kehrt sich um



Weitere Besonderheiten von OT-Umgebungen

- **Fernwartungszugänge:** Hersteller warten Anlagen zunehmend per Fernzugriff – zusätzliche Angriffsfläche
- **Industrie 4.0 / IIoT:** bisher isolierte Anlagen werden zur Vernetzung mit der Büro-IT und dem Internet verbunden
- Ein erfolgreicher Angriff wirkt sich **physisch** aus: Maschinenschäden, Produktionsausfälle, im Extremfall Gefahr für Menschen

Merksatz: In der IT verliert man Daten – in der OT können Maschinen explodieren.

Das Smart Home

Consumer-IoT und das Mirai-Botnet

Was ist Consumer-IoT / Smart Home?

- **Internet of Things (IoT):** Alltagsgegenstände mit Internetverbindung, Sensorik und eigener Intelligenz
- Typische Smart-Home-Geräte: IP-Kameras, smarte Steckdosen, Türschlösser, Lautsprecher, Router, Babyphones
- Gemeinsamkeit: **billig, massenhaft verkauft, dauerhaft online**
- Im Gegensatz zur Industrieanlage: kein Sicherheitsteam, kein IT-Admin – der Nutzer selbst ist verantwortlich

Warum Smart-Home-Geräte so anfällig sind

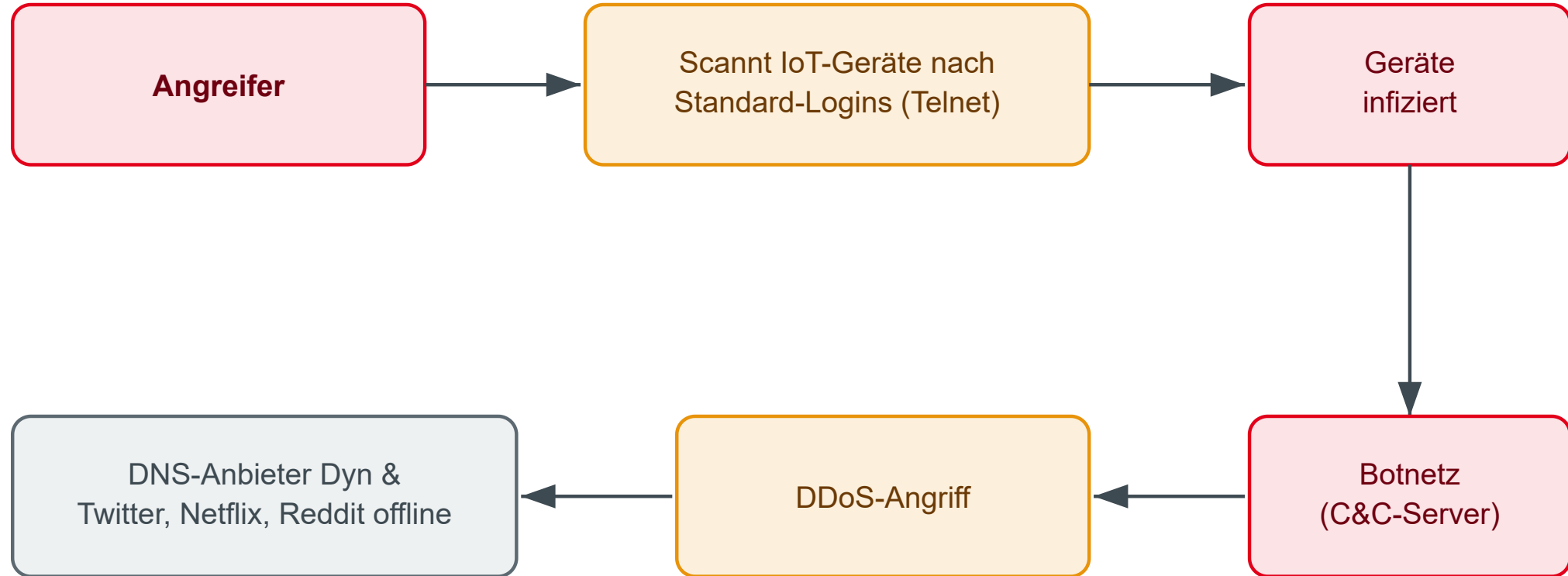
- **Kostendruck:** Sicherheit kostet Entwicklungszeit – bei Billigware oft die erste Einsparung
- **Keine Update-Mechanismen:** viele Geräte erhalten nie ein Sicherheitsupdate, manche Hersteller existieren nach Jahren nicht mehr
- **Monokultur:** dieselbe Firmware steckt in tausenden baugleichen Geräten weltweit – eine Schwachstelle betrifft alle gleichzeitig
- **Immer online:** Geräte laufen 24/7 und sind oft direkt aus dem Internet erreichbar

Fallstudie: Mirai-Botnet (2016)

- Was geschah?
 - Schadsoftware scannte automatisiert das Internet nach IoT-Geräten mit offenem **Telnet-Zugang**
 - Testete dabei eine Liste von rund **60 Standard-Benutzername/Passwort-Kombinationen** (z. B. `admin` / `admin`)
 - Infizierte so hunderttausende Kameras, Router und Digitalrekorder – ganz ohne komplexe Exploits

Telnet: älterer Fernzugangsdienst zur Anmeldung am Gerät. Standard-Zugangsdaten erlaubten Mirai, sich an schlecht gesicherten Geräten anzumelden.

Mirai-Botnet als Diagramm



Konsequenzen & Lehren aus Mirai

- **Konsequenzen:** großflächiger Ausfall bekannter Internetdienste, verstärkte regulatorische Debatten über IoT-Mindeststandards
- Der Quellcode wurde veröffentlicht – seither Basis unzähliger Varianten und Nachfolge-Botnetze
- **Lehre:** Ein einzelnes unsicheres Gerät gefährdet nicht nur seinen Besitzer, sondern potenziell das gesamte Internet

Merksatz: Das schwächste Glied im IoT ist selten das Gerät selbst – es ist das Standardpasswort.

OWASP IoT Top 10

Die häufigsten Schwachstellenkategorien
im Überblick

Die OWASP IoT Top 10 (2018)

#	Kategorie
I1	Schwache, erratbare oder fest codierte Passwörter
I2	Unsichere Netzwerkdienste
I3	Unsichere Ecosystem-Schnittstellen (App, Cloud, API)
I4	Fehlender sicherer Update-Mechanismus
I5	Einsatz unsicherer oder veralteter Komponenten

Beispiel für I3: Eine sichere Kamera hilft wenig, wenn ihre Smartphone-App oder Cloud-Schnittstelle unberechtigt auf Aufnahmen zugreifen lässt.

Die OWASP IoT Top 10 (2018)

#	Kategorie
I6	Unzureichender Datenschutz
I7	Unsichere Datenübertragung & -speicherung
I8	Fehlendes Geräte-Management
I9	Unsichere Standardeinstellungen
I10	Fehlende physische Absicherung

Vertiefung: I1 – Schwache/fest codierte Passwörter

- Geräte werden mit **Standard-Zugangsdaten** ausgeliefert, die Nutzer selten ändern
- Manche Geräte haben zusätzlich **fest codierte** (hardcoded) Zugänge, die sich gar nicht ändern lassen
- **Bereits gesehen bei:** Mirai-Botnet – Infektion allein über ausprobierte Standard-Logins

Vertiefung: I4 – Fehlender sicherer Update-Mechanismus

- Viele IoT-Geräte haben **keinen** oder nur einen unsicheren Weg, um Sicherheitsupdates zu erhalten
- Betrifft Consumer-Geräte (nie ein Update) **und** Industrieanlagen (Updates nur im geplanten Stillstand)
- Ohne Update-Mechanismus bleibt eine einmal bekannte Schwachstelle **dauerhaft** ausnutzbar

Zusammenfassung

Bereich	Kernrisiko	Beispiel
Industrieanlagen (OT)	Verfügbarkeit vor Vertraulichkeit, lange Lebensdauer	Stuxnet
Smart Home (Consumer-IoT)	Kostendruck, keine Updates, Monokultur	Mirai-Botnet
OWASP IoT Top 10	Strukturierte Übersicht typischer Schwachstellen	I1, I4

Merksatz: IoT-Sicherheit bedeutet, Sicherheit für Geräte zu denken, die niemand administriert.

Diskussionsfragen

- Wer sollte verantwortlich sein, wenn ein günstiges IoT-Gerät nie ein Sicherheitsupdate erhält – Hersteller, Händler oder Nutzer?
- Sollten Industrieanlagen gesetzlich verpflichtet werden, Sicherheitsupdates auch außerhalb geplanter Stillstände einzuspielen?